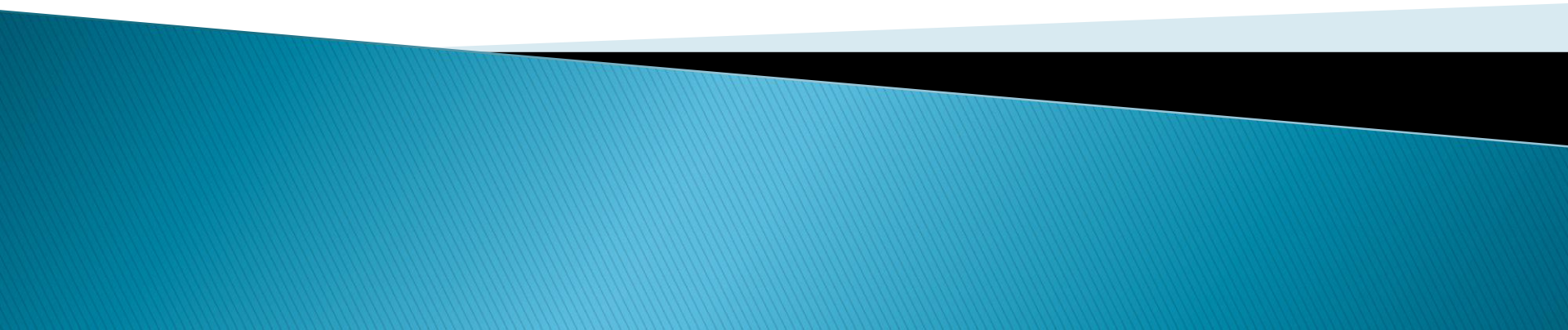


Computer Security and Cyber Law

Unit 10

Policy and Procedure

Lecturer: Binod Chandra Shrestha



Computer Crime

- Computer crime refers to any crime that involves a computer and a network.
- The computer may have been used in the commission of a crime, or it may be the target.
- EG:—downloading illegal music files, to stealing millions of dollars from online bank accounts, Cybercrime also includes non-monetary offenses, such as creating and distributing viruses on other computers or posting confidential business information on the Internet.

Computer Crime categories

1. Computer as targets – attacking the computers of others (spreading viruses is an example).
under the attack are the confidentiality, integrity, accessibility, authorization, availability of the information and the services provided.
--- Active
2. Computers as data repositories :– Using a computer as a "fancy filing cabinet" to store illegal or stolen information. – Passive
3. Computer as a tool for committing a crime (even as a communication device).

Note:– (1) and (2) – computer as an object, (3) computer as a subject

Stakeholders

- ▶ National security
- ▶ National institutions
 - Customs
 - Police
 - Civil and criminal courts
 - NGOs
 - Academia
 - Schools
- ▶ Businesses
 - Corporate crime
 - Compliance
 - Insurance companies
- ▶ International security
- ▶ Individuals/personal level

Cyber Crime

- Cybercrime is criminal activity done using computers and the Internet.
- Cyber crime encompasses any criminal act dealing with computers and networks.
- It also includes traditional crimes conducted through the Internet. For example; hate crimes, telemarketing and Internet fraud, identity theft, and credit card account thefts are considered to be cyber crimes when the illegal activities are committed through the use of a computer and the Internet.
- It includes anything from downloading illegal music files to stealing millions of dollars from online bank accounts etc.
- Cybercrime also includes non-monetary offenses, such as creating and distributing viruses on other computers or posting confidential business information on the Internet.

Digital and Cyber Forensics

- Computer forensics
- Institutional and corporate security
- System programming for forensic computing
- Legal issues and institutions
- Internet forensics and investigations
- Network forensics and investigations
- e-Crimes: From fraud to terrorism
- Cyberspace forensics and investigations

What is Digital Forensics?

- is the discovery, recovery, and investigation of digital information
- Digital forensics is a branch of computer science that focuses on developing evidence pertaining to digital files for use in civil or criminal court proceedings. Digital forensic evidence would relate to a computer document, email, text, digital photograph, software program, or other digital record which may be at issue in a legal case

What is Digital Forensics?

- Digital forensics is a branch of forensic science encompassing the recovery and investigation of material found in digital devices, often in relation to computer crime.
- The technical aspect of an investigation is divided into several sub-branches, relating to the type of digital devices involved; computer forensics, network forensics, database forensics and mobile device forensics.

Computer security

- Informational assets remain in the appropriate state of assurance by demonstrating
 - Confidentiality
 - Integrity
 - Availability
 - Authenticity
- Countermeasures for protection
 - Preventive
 - Mitigating
 - Transferring (outsourcing)
 - Recovery

Forensics vs. Security

▶ Security

- wants to preserve the digital system the way it is
 - observing the policy that has been defined
- Focus is on (security) policy enforcement and the adequate roles are dressed up in hierarchy of access rights

▶ Forensics

- attempts to explain how the policy came to be violated, which may eventually lead to finding flaws and making improvements in the future.
- Risk assessment

Computer/data/cyber forensics

- ▶ The lawful and ethical seizure, acquisition, analysis, reporting and safeguarding of data and meta-data derived from digital devices which may contain information that is notable and perhaps of evidentiary value to the trier of fact in managerial, administrative, civil and criminal investigations (L. Leibrock, 1998)

Digital Evidence

- What is evidence?
 - Evidence in its broadest sense includes everything that is used to determine or demonstrate the truth of an assertion
- What is digital evidence?
 - Digital evidence or electronic evidence is any information stored or transmitted in digital form that a party to a court case may use at trial.
 - Before accepting digital evidence a court will determine if the evidence is relevant, whether it is authentic, if it is hearsay and whether a copy is acceptable or the original is required

Forensic elements

- Material
 - Physical
 - Electronic (digital)
- Relevance
 - Stakeholders (victims, private individuals, government, insurance companies, legal institutions, law enforcement agencies)
- Validity (close to relevance and the process of authentication)

Investigative procedures

- ▶ 3As [Kruse and Heiser]
 - Acquiring the evidence
 - Authenticating the validity of the extracted or retrieved data
 - Analyzing the data

Categories of Evidence

- Impressions (fingerprints, tool marks, footwear marks)
- Bioforensics (blood, body fluids, hair, nail scrapings, and blood stain patterns)
- Trace evidence (residue of the things used for committing the crime like arson accelerant, paint, glass, fibers).
- Material evidence (letters, folders, scrapped paper – in a way a hard copy stuff)

Where to focus and how to start

- ▶ What are we going to work with:
 - Policies, technical procedures, permissions, billing statements, system utilities, applications, and various logs
- ▶ Whom and what we want to monitor:
 - Employees, employers, access rights, email, surfing logs, and chat room records.

Case assessment and requirements

- ▶ Situation – local and global environment
- ▶ Nature of the case
- ▶ Specifics
- ▶ Types of evidence
- ▶ Operating system – working environment
- ▶ Archive storage formats
- ▶ Location of evidence

Handling evidence

- ▶ Includes extraction and establishment of a chain-of-custody, which also involves packaging, storage, and transportation
- ▶ Who extracted the evidence and how?
- ▶ Who packed it?
- ▶ Who stored the evidence, how and where?
- ▶ Who transported it?

Handling evidence

- Case
 - Number
 - Investigator/institution/organization
 - Nature of the case
- Equipment
 - For all computers and devices involved – manufacturer, vendor, model, and serial number
- Evidence
 - Location
 - Recording entity
 - Time and date of recording

All of this sometimes is qualified as a chain-of-evidence.

Evidence recovery

- Extraction depends on the nature of the incident and the type of equipment or system involved (computer, operating environment, network)
- Rule of thumb – extract and collect as much as you can (avoid going back – most of the time it is impossible)
- Compress the evidence with lossless compression tools
- Some hashing (MD5, CRC, or SHA-1 / 2 / 3) should be done for integrity after storage and transportation

Preserving evidence

- ▶ No single standard
- ▶ Packaging and extra storage measures – digital evidence may be a disappearing act
- ▶ Back-ups
- ▶ Document
- ▶ Control access
- ▶ Validate and/or authenticate data based on standard procedures

Transporting evidence

- ▶ One has to protect the chain-of-custody
- ▶ Strong data hiding techniques – encryptions, passwords, steganography
- ▶ Assurance of the preserved content
- ▶ Test possible changes and modifications

Analysis of evidence

- ▶ Fairly long and painstaking process
- ▶ Diversified
 - From shortcuts to recycle bins and registries
 - Every data medium and data type
 - All encrypted and archived files
- ▶ Hard drive physical analysis
- ▶ Hard drive logical analysis
- ▶ Depends on the platforms and the tools used

Intellectual Property

- Intellectual property (IP) is a controversial term referring to a number of distinct types of **creations of the mind**(intangible property created by individuals or organization) for which a set of rights are recognized under the corresponding fields of law.
- IP is divided into two categories:
 - Industrial property, which includes inventions (patents), trademarks, industrial designs, etc.
 - Copyright, which includes literary and artistic works such as novels, poems and plays, films, musical works, drawings, paintings, photographs ,architectural designs, etc

Intellectual Property Right

- ▶ Under intellectual property law, owners are granted certain exclusive rights to a variety of intangible assets.
- ▶ Intellectual property rights are like any other property right. They allow creators, or owners, of patents, trademarks or copyrighted works to benefit from their own work or investment in a creation.

Copyrights

- the exclusive right of the author or creator of a literary or artistic property (such as a book, movie, or musical composition) to print, copy, sell, license, distribute, transform to another medium, translate, record or perform or otherwise use (or not use) and to give it to another by will.
- As soon as a work is created and is in a tangible form (such as writing or taping) the work automatically has federal copyright protection
- stating the word copyright, or copy or "c" in a circle, with the name of the creator, and the date of copyright
- Copyright is protection for creators of "original works of authorship," including musical, dramatic, literary, architectural, and other works
- author's life + 70 years in U.S.

Trademark

- A trademark is a distinctive sign that identifies certain goods or services produced or provided by an individual or a company.
- The system helps consumers to identify and purchase a product or service based on whether its specific characteristics and quality – as indicated by its unique trademark – meet their needs.
- Trademark protection ensures that the owners of marks have the exclusive right to use them to identify goods or services, or to authorize others to use them in return for payment.
- The period of protection varies, but a trademark can be renewed and Trademark protection is legally enforced by courts.
- Trademark protection also hinders the efforts of unfair competitors, such as counterfeiters, to use similar distinctive signs to market inferior
 - or different products or services
 - drawings, symbols, color and non-visible signs (sound, smell or taste) etc.

Licenses

- formal permission from a governmental or other constituted authority to do something, as to carry on some business or profession.
- The certificate or the document itself that confers permission to engage such as a certificate, tag, plate, etc., giving proof of such permission; official permit: a driver's license.
- permission to do or not to do something.
- intentional deviation from rule, convention, or fact, as for the sake of literary or artistic effect: poetic license.

Agreements

- A meeting of minds with the understanding and acceptance of reciprocal legal rights and duties as to particular actions or obligations, which the parties intend to exchange; a mutual assent to do or refrain from doing something; a contract.
- The writing or document that records the meeting of the minds of the parties. An oral compact between two parties who join together for a common purpose intending to change their rights and duties.
- An agreement is not always synonymous with a contract because it might lack an essential element of a contract, such as consideration.
- any meeting of the minds, even without legal obligation.
- in law, another name for a contract including all the elements of a legal contract: offer, acceptance, and consideration (payment or performance), based on specific terms.

Plagiarism

- Plagiarism is theft of another person's writings or ideas.
- Generally, it occurs when someone steals expressions from another author's composition and makes them appear to be his own work.
- Plagiarism is not a legal term; however, it is often used in lawsuits. Courts recognize acts of plagiarism as violations of Copyright law, specifically as the theft of another person's Intellectual Property.

Cyber Law

- IT Law is a set of legal enactments, which governs the digital dissemination of both (digitalized) information and software itself. IT Law covers mainly the digital information (including information security and electronic commerce) aspects and it has been described as "paper laws" for a "paperless environment".
- Cyberlaw or Internet law is a term that encapsulates the legal issues related to use of the Internet. It is less a distinct field of law than intellectual property or contract law, as it is a domain covering many areas of law and regulation.
- Cyber law is a term used to describe the legal issues related to use of communications technology, particularly "cyberspace", (Internet).
- It is less a distinct field of law in the way that property or contract are, as it is an intersection of many legal fields, including intellectual property, privacy, freedom of expression, and jurisdiction. In essence, cyber law is an attempt to apply laws designed for the physical world to human activity on the Internet.

Digital Rights Management (DRM)

- ▶ DRM refers to a collection of systems used to protect the copyrights of electronic media. These include digital music and movies, as well as other data that is stored and transferred digitally.
- ▶ For example, the Apple iTunes Music Store uses a DRM system to limit the number of computers that songs can be played on. Each audio file downloaded from the iTunes music store includes information about the owner of the file and how many times the file has been transferred. The protected files will not play on computers that have not been authorized to play the music.
- ▶ Digital Rights Management is important to publishers of electronic media since it helps ensure they will receive the appropriate revenue for their products. By controlling the trading, protection, monitoring, and tracking of digital media, DRM helps publishers limit the illegal propagation of copyrighted works. This can be accomplished by using digital watermarks or proprietary file encryption on the media they distribute. Whatever method publishers choose to employ, DRM helps them make sure that their digital content is only used by those who have paid for it.

ETA and more

- ▶ Electronic Transaction Act,
- ▶ Electronics Transaction Rules,
- ▶ IT Policy,
- ▶ Information Security and policies,
- ▶ Introduction to E-government,
- ▶ Introduction to electronic contracts.

Electronic Transaction Act and Rule

- ▶ Electronic Transaction Act–2008 and Electronic Transaction Rule–2010
- ▶ To make legal provisions for authentication and regularization, validity, integrity and reliability of generation, production, processing, storage of electronic records and generating secure digital signature
- ▶ Controller of Certification Authority (CCA) has been established
- ▶ Sometime there is dilemma in working between different entities say who regulates for content?

IT Policy, 2010

- ▶ Vision: To place Nepal on the global map of information technology within the next five years
- ▶ The information technology policy shall be formulated to achieve the following objectives:
 - To make information technology accessible to the general public and increase employment through this means,
 - To build a knowledge-based society, and
 - To establish knowledge-based industries.

Introduction to E-government

- The employment of the Internet and the world-wide-web for delivering government information and services to the citizens.
- The utilization of IT, ICTs, and other web-based telecommunication technologies to improve and/or enhance on the efficiency and effectiveness of service delivery in the public sector.
- E-government describes the use of technologies to facilitate the operation of government and the disbursement of government information and services.
- E-government, short for electronic government, deals heavily with Internet and non-internet applications to aid in governments.
- E-government includes the use of electronics in government as large-scale as the use of telephones and fax machines, as well as surveillance systems, tracking systems such as RFID tags, and even the use of television and radios to provide government-related information and services to the citizens.

Introduction to E-government

- E-Government (short for electronic government, also known as e-gov, digital government, online government, or connected government) is digital interactions between a government and citizens (G2C), government and businesses/Commerce (G2B), government and employees (G2E), and also between government and governments /agencies (G2G).
- The e-Government delivery models are
 - G2C (Government to Citizens)
 - G2B (Government to Businesses)
 - G2E (Government to Employees)
 - G2G (Government to Governments)
 - C2G (Citizens to Governments)

Information Security and Policy

- ▶ A security policy is a document that states in writing how a company plans to protect the organization's physical and information technology assets.
- ▶ A security policy is often considered to be a "living document", meaning that the document is never finished, but is continuously updated as technology and employee requirements change.
- ▶ An organization's security policy may include an acceptable use policy, a description of how the organization plans to educate its employees about protecting the organization's assets, an explanation of how security measurements will be carried out and enforced, and a procedure for evaluating the effectiveness of the security policy to ensure that necessary corrections will be made.

▶ **Type of online contract:**

- **Business-to-business (B2B)** includes suppliers of raw materials, parts and components and wholesalers to retail. Electronic Data Interchange (EDI) systems may replace paper with the standards specified as part of the contract.
- **Business-to-consumer (B2C)** includes sites such as Amazon.com that use online catalogs and price lists. Purchases may be made online, via fax, phone or mail. Payments may be electronic or physical. Goods may be delivered or picked up.
- **Consumer-to-consumer (C2C)** includes sites such as eBay, online want ads, auctions or flea markets.

Assignment 10

1. What is computer? Explain its categories.
2. What is digital forensic? Explain the stages of digital forensic.
3. What is digital evidence? Explain its categories.
4. What is intellectual property? Explain its different types.
5. What is digital right management (DRM)? Explain different technologies used for DRM.
6. Write short notes on:
 - a) Cyber Law
 - b) IT Policy of Nepal
 - c) Information security and policy